G I O I · BALI RESERVATION PLATFORM

Security Scan & Remediation Report

apps/api (Fastify) · apps/web (Nuxt)

SAST · SCA · DAST | 2026-11-08 | branch development

Executive summary

Both apps were scanned on commit f61b15f with Semgrep (SAST), OSV.dev via cve-mcp-server (SCA) and OWASP ZAP baseline (DAST). SAST found nothing. The findings are dependency advisories and missing response headers. Overall risk is low to moderate; no advisory is in CISA KEV and the highest EPSS is 0.0103.

0	7 of 10	3	10
SAST findings	Advisories fixed	Advisories open (nuxt)	DAST header warnings

Remediation applied

Package	App	From	To	Advisories closed
vitest	api, web	2.1.9	4.1.12	CVE-2026-47429 (critical, UI file read/exec), CVE-2026-84373 (mocker path traversal)
happy-dom	web	15.11.7	^21	CVE-2025-61927, CVE-2026-33943, CVE-2026-118660, CVE-2026-118661, CVE-2026-34226

All fixed packages are devDependencies and are not shipped to production. After the upgrade the web vitest run passes and `nuxt build` completes.

Open: nuxt

Three nuxt advisories (CVE-2026-114130, -114132, -114133) are fixed only in Nuxt 4. Upgrading to 4.6.4 was tried and reverted: `@pinia/nuxt` was disabled as incompatible and the `/bali` prerender returned 500. Only CVE-2026-114132 (route rules skipped for case-variant paths) touches this app, because `/admin/**`, `/host` and `/guests/**` rely on routeRules. The other two are inactive here (the app uses pages/ and no server islands).

Findings by layer

SAST · Semgrep

389 and 390 rules ran on 47 (api) and 41 (web) tracked files with 0 findings.

SCA · OSV.dev

Package	Advisory	Severity	EPSS	Status
vitest	GHSA-5xrq-8626-4rwp	Critical	0.0103	Fixed
vitest	GHSA-82fw-gwwq-j7x9	Moderate	0.0053	Fixed
happy-dom	GHSA-37j7 / 5fpq / 6q6h / c8p4 / w4gp	Mixed	≤ 0.0065	Fixed
nuxt	GHSA-vjh5-4x84-xrqp	Moderate	0.0042	Open (Nuxt 4)
nuxt	GHSA-jjm6-p2m9-9w4x	Low	0.0041	Open, inactive path
nuxt	GHSA-xfq5-w38q-pc2x	n/a	0.0022	Open, inactive path

DAST · OWASP ZAP baseline (passive)

API: 67 pass, 1 warn (cacheable 404s). Spider reached only the root, so routes such as /health, venues and reservations were not exercised. Web: 58 pass, 10 warn, 0 fail across 46 URLs. All warnings are hardening gaps.

Alert	ID	Fix
Content Security Policy not set	10038	Add Content-Security-Policy via routeRules headers
Missing anti-clickjacking header	10020	X-Frame-Options or frame-ancestors
X-Content-Type-Options missing	10021	nosniff
Permissions Policy not set	10063	Add Permissions-Policy
Cross-Origin-Embedder-Policy missing	90004	Add COEP header
X-Powered-By disclosure	10037	Disable the header in nitro config
Sub Resource Integrity missing	90003	Add integrity to external assets
Cacheable content / cross-domain	10049, 10098	Review cache headers

Next steps

#	Action	Why	Effort
1	Migrate web to Nuxt 4: bump @pinia/nuxt and pinia to 3.x, fix the /bali prerender, adopt the app/ source layout	Closes the last three advisories, including the routeRules bypass	Medium
2	Add security headers in nuxt.config.ts routeRules (CSP, X-Frame-Options, nosniff, Permissions-Policy, COEP)	Clears 9 of 10 ZAP warnings	Small
3	Provide an OpenAPI spec or route list for the API and rerun ZAP	Current DAST covers only the root path	Small
4	Wire Semgrep and an OSV scan into CI	Scans are ad hoc today	Small

Method and limits: versions were read from installed node_modules. CVSS scores are vectors only where OSV published no numeric score. DAST is passive; no active attacks were run. Raw outputs: /tmp/gioi-{api,web}-semgrep.json, cve-mcp.json, zap/zap-report.json.